

Audit fonctionnel, bugs et améliorations

Date : 17 août 2026

Version iPad disponible : 1.0.0+6 via TestFlight

Version Web/API déployée : commit 56cc72218c4de591dc0308dd97d85ed7aac106de

Cibles actuelles : iPad natif via TestFlight et application web sur Mac

Lecture des statuts

- **Terminé** : fonction présente et couverte par un contrôle automatisé ou un contrôle réel de production.
- **En cours** : code présent et contrôles verts, mais livraison ou validation terrain encore incomplète sur au moins une cible.
- **Restant** : fonction absente, incomplète ou validation indispensable non réalisée.
- **Hors périmètre** : plateforme non ciblée par la version terrain actuelle.

Synthèse

Indicateur	Résultat
Bug métier bloquant reproduit	0
Lot synchronisation, authentification et batching	Relu, consolidé, engagé et poussé
Tests Flutter	123 réussis
Tests de contrat de synchronisation	10 réussis
Parcours critiques statiques	17 réussis
Tests Node ciblés après correction	13 réussis
Vulnérabilités npm connues	0 dans le commit déployé
Secrets suivis détectés	0 dans le commit déployé
Contrôles de cohérence production	40 réussis
Build web Flutter	Réussi
Déploiement Web/API	Même commit 56cc722, opérationnel
Contrôle authentifié Coralie	Conforme, rôle ERGO, 7 dossiers
Contrôle authentifié Christelle	Conforme, rôle ERGO, 12 dossiers
Contrôle authentifié Renan	Conforme, rôle ADMIN, 19 dossiers
État production au moment de l'audit	Web, API, CORS, CSP et NocoDB opérationnels

Conclusion : aucun blocage métier n'est reproduit par les contrôles exécutés. Le lot de synchronisation, d'authentification et de batching est désormais relu, poussé et déployé sur le Web et l'API depuis le même commit. Les accès et le filtrage des dossiers ont été validés en production pour Coralie, Christelle et Renan. La validation restante la plus importante est un aller-retour terrain complet sur iPad avec la prochaine version TestFlight contenant ce commit. Les annotations PDF par page restent locales uniquement et un rapport ne restitue toujours pas plus de huit préconisations.

État de livraison

Composant	Version ou commit	État	Observation
Flutter Web	56cc722	Déployé	Workflow GitHub réussi, application accessible sur https://app.aidhabitat.fr
API EasyPanel	sha-56cc722	Déployé	Image active et contrôles <code>live</code> et <code>ready</code> conformes
iPad TestFlight	1.0.0+6	Disponible	Ne contient pas automatiquement les derniers changements Flutter du commit 56cc722
Dépôt Git	56cc722	Propre	<code>main</code> et <code>origin/main</code> alignés, aucun changement local en attente au moment du contrôle
Automatisation API	Build & Deploy API	Incomplète	Le secret GitHub <code>EASYPANEL_API_WEBHOOK</code> manque ; le déploiement actuel a été effectué manuellement

Tableau fonctionnel

Priorité	Domaine	Fonctionnalité	Statut	Vérification réalisée	Reste à faire
P0	Connexion	Connexion locale après une première authentification serveur	Terminé	Tests Flutter d'authentification et de persistance réussis	Refaire un test terrain par profil après la prochaine livraison
P0	Connexion	Ne pas déconnecter l'utilisateur lors d'une panne réseau, TLS, API ou NocoDB	En cours	Correctif déployé sur le Web, tests de session distante et erreurs transitoires réussis	Intégrer le commit au prochain build iPad puis simuler une panne API sans quitter le dossier
P0	Connexion	Renouvellement silencieux de la session distante	En cours	Refresh token validé en production, stockage sécurisé et rejet d'un refresh token comme jeton d'accès confirmé	Valider l'expiration réelle du jeton dans la prochaine version iPad
P0	Synchronisation	Sauvegarde locale immédiate des formulaires et notes	Terminé	Tests de persistance hors ligne et redémarrage réussis	Conserver le test terrain d'une journée dans la checklist de release
P0	Synchronisation	Push local avant pull distant pour éviter l'écrasement des saisies	En cours	Contrat et tests automatisés réussis, Web/API déployés ensemble	Valider sur la prochaine version iPad et comparer iPad, NocoDB et Web après une journée hors ligne
P0	Synchronisation	Regroupement des petites écritures en lots API	Terminé Web/API	Endpoint <code>/api/sync/batch</code> , contrats et tests réussis ; Web et API déployés depuis 56cc722	Inclure le client Flutter correspondant dans le prochain build iPad et surveiller une reprise réelle
P0	Synchronisation	Conservation et ordre des opérations après erreurs transitoires	En cours	La file locale conserve l'opération fautive et bloque les mutations suivantes du même objet ; tests réussis	Confirmer sur iPad qu'une panne temporaire ne provoque ni perte ni bandeau rouge persistant
P0	Données	Bénéficiaires, dossiers, logements, contexte, autonomie, mesures et sanitaires	Terminé	Contrats de champs, 40 contrôles NocoDB et 123 tests Flutter réussis	Maintenir un échantillon manuel multi-appareils dans la checklist de release
P0	Données	Protection des modifications <code>pendingSync</code> contre un pull plus ancien	Terminé	Tests de fusion et de persistance réussis	Ajouter à terme un scénario E2E automatisé multi-appareils
P0	Rapports	Génération PDF différée tant que les données ne sont pas distantes	Terminé	Parcours critique contrôlé et service de génération différée présent	Revalider sur un dossier modifié hors ligne avec plusieurs notes et photos
P1	Documents	Import, photo, scan natif et aperçu des documents	Terminé	Build, tests, configuration iOS et scanner natif contrôlés	Faire un essai matériel après chaque changement de plugin iOS
P1	Documents	Annotation d'une page PDF sans dupliquer le dessin sur les autres pages	Terminé localement	Stockage par numéro de page et tests de comportement présents	Voir la ligne suivante pour la synchronisation multi-appareils

Priorité	Domaine	Fonctionnalité	Statut	Vérification réalisée	Reste à faire
P1	Documents	Synchronisation serveur des annotations PDF par page	Restant	Le dépôt indique explicitement <code>local-only</code> dans <code>document_repository.dart</code>	Ajouter une opération <code>update_annotations</code> , son endpoint, ses tests de conflit et sa persistance NocoDB
P1	Rapports	Plus de huit préconisations dans le PDF	Restant	Le générateur incrémente <code>recoveryFlow</code> puis ignore les éléments supplémentaires	Générer des pages supplémentaires ou bloquer explicitement l'ajout au huitième élément
P1	Dessin	Notes dessin, gomme, pages, plans et Apple Pencil	Terminé	Tests Flutter, bridge Pencil et build iPad contrôlés	Test matériel rapide, double-tap et traits courts avant chaque build TestFlight
P1	Notes	Notes écrites, pagination, dictée native iPad	Terminé	Tests Flutter et configuration native présents	Test matériel dictée française et sauvegarde après retour en ligne
P1	Photos	Photos de visite, cache local et reprise d'upload	Terminé	Parcours critique et cache hors ligne présents	Tester un lot volumineux sur réseau faible
P1	Visite	Onglets bénéficiaire, contexte, mesures, accessibilité, salle de bain, WC, plans, photos, résumé et préconisations	Terminé côté code	Build et tests de modèles/services réussis	Parcours manuel complet à rejouer sur la prochaine version iPad
P1	Dossiers	Filtrage des dossiers selon l'ergothérapeute et accès global admin	Terminé	Contrôle authentifié en production : Coralie 7 dossiers, Christelle 12, Renan 19	Rejouer uniquement après une modification des membres, rôles ou affectations
P1	Référentiels	Communes, EPCI, caisses principales et complémentaires	Terminé	Données distantes disponibles et cache hors ligne implémenté	Contrôle visuel authentifié des sélecteurs sur iPad
P1	Bibliothèque	Wiki, filtres, images locales et préconisations	Terminé	Assets intégrés au build et cache hors ligne implémenté	Contrôle visuel authentifié des 54 images après chaque changement d'assets
P1	ANAH	Portail intégré sur iPad et ouverture externe de secours	Terminé côté code	Configuration native et build valides	Revalider le certificat et le chargement réel du portail sur iPad
P1	Distribution	Version iPad interne via TestFlight	Terminé pour 1.0.0+6	Version installable par l'équipe et signatures Apple opérationnelles	Créer un nouveau build uniquement pour embarquer les changements Flutter postérieurs
P1	Sécurité	Vulnérabilités Node de sévérité haute	Terminé	<code>npm audit --omit=dev --audit-level=high</code> retourne zéro vulnérabilité sur le commit déployé	Maintenir le contrôle dans la CI
P1	Sécurité	Audit des secrets suivis par Git	Terminé pour l'état courant	Zéro secret détecté sur le commit déployé	Révoquer et purger séparément tout ancien jeton réellement exposé dans l'historique Git
P2	Web	Application, API, CSP, CORS et accès NocoDB	Terminé	Contrôles live et release réussis sur les URL de production	Conserver les checks après chaque déploiement EasyPanel
P2	Déploiement	Déploiement API automatique depuis GitHub	Restant	Le build d'image réussit, mais l'étape EasyPanel échoue faute de <code>EASYPANEL_API_WEBHOOK</code>	Ajouter ce secret GitHub puis relancer le workflow sur un prochain commit
P2	Web	Taille du bundle Vite historique	Restant	Build réussi, chunk principal d'environ 547 kB	Découper le bundle seulement si cette interface React reste utilisée
P2	Stockage	Vérification de capacité et d'orphelins depuis un backup	Restant	Outil présent mais inutilisable sans fichier de sauvegarde	Fournir un export <code>.json</code> ou <code>.json.gz</code> , puis lancer <code>npm run storage:readiness</code>
P2	Sécurité	Verrouillage après inactivité et biométrie	Restant	Non implémenté	Définir la durée de verrouillage et le comportement hors ligne avant développement
P2	Conformité	Registre RGPD, conservation, sous-traitants et adéquation HDS	Restant	Hors du contrôle technique automatique	Validation juridique et organisationnelle dédiée
P2	Documentation	Anciens documents d'architecture encore rédigés au futur	Restant	Plusieurs audits décrivent l'offline-first comme non réalisé	Archiver ou mettre à jour ces documents pour éviter les décisions basées sur un état obsolète
P3	Dépendances	Mises à jour majeures Flutter	Restant	71 versions plus récentes mais incompatibles sont signalées	Mettre à jour par lots avec tests de régression, pas pendant la stabilisation terrain

Parcours utilisateurs testés

Parcours	Automatisé	Visuel ou production	Résultat	Réserve
Ouverture de l'application web	Oui	Oui, production	Conforme	Aucune erreur initiale observée
Connexion	Oui	Sessions de production validées pour les trois profils	Conforme	Les mots de passe réels n'ont pas été ressaisis pendant ce contrôle ; leur stockage <code>script</code> a été vérifié
Restauration de session et connexion hors ligne	Oui	Non rejouée manuellement	Conforme dans les tests	Validation terrain après livraison requise
Chargement des dossiers	Oui indirectement	API authentifiée et NocoDB contrôlés	Conforme	Coralie 7 dossiers, Christelle 12, Renan 19
Modification bénéficiaire et contexte de vie	Oui	Cohérence production contrôlée	Conforme	Test multi-appareils à refaire après livraison
Notes écrites et dessin	Oui	Non rejoué avec Apple Pencil	Conforme dans les tests	Validation matérielle iPad nécessaire
Ajout, suppression et réordonnancement des préconisations	Oui indirectement	Non rejoué manuellement	Conforme côté données	PDF limité à huit éléments
Photos, documents et scan	Oui indirectement	Configuration iOS contrôlée	Conforme côté code	Test scanner matériel non rejoué
Annotation PDF	Partiel	Non rejouée	Fonction locale conforme	Synchronisation distante absente
Génération PDF en ligne	Oui indirectement	API prête et authentification serveur conforme	Conforme côté service	Génération complète non rejouée avec un nouveau dossier pendant cet audit
Génération demandée hors ligne puis reprise	Oui	Non rejouée pendant cet audit	Conforme dans les tests	Test terrain prioritaire
Wiki et caisses de retraite	Oui indirectement	Assets présents dans le build	Conforme côté code	Contrôle visuel authentifié non rejoué
Portail ANAH	Build uniquement	Non rejoué pendant cet audit	À revalider	Dépend du site et de son certificat
Paramètres et gestion des accès	Oui indirectement	Non rejoué manuellement	Conforme côté code	Tester avec un compte admin dédié

Affichages par appareil

Appareil	Taille vérifiée	Résultat	Niveau de support
Mac, application web	1440 x 900	Connexion lisible, centrée et sans débordement	Cible supportée
iPad paysage	1180 x 820	Connexion lisible, centrée et sans débordement	Cible principale

Corrections appliquées pendant l'audit

1. Mise à jour compatible du verrou npm afin de supprimer les vulnérabilités connues de `fast-uri`, `hono`, `ip-address`, `nanoid`, `postcss` et `shell-quote`.
2. Renommage de trois variables de test ou temporaires afin que l'audit de secrets ne confonde plus des valeurs fictives avec de vrais identifiants.

3. Consolidation du renouvellement de session et du stockage sécurisé côté Flutter.
4. Ajout et validation du batching API afin de limiter les rafales d'appels lors du retour en ligne.
5. Conservation de l'ordre des mutations d'un même objet après une erreur transitoire, sans abandon ni écrasement de la file locale.
6. Réduction du cache d'authentification serveur à dix secondes et réutilisation du registre en cache lors de la signature des jetons.
7. Refus explicite des refresh tokens sur les endpoints métier et les fichiers privés.
8. Ajout de contrôles CI de cohérence de la synchronisation et de stabilité des données.

Ces corrections sont incluses dans [56cc722](#), poussées sur `main` et déployées sur le Web et l'API. Aucun mot de passe n'a été réinitialisé et aucune donnée métier NocoDB n'a été modifiée pendant les tests authentifiés.

Ordre recommandé

1. Produire un nouveau build TestFlight depuis le commit stabilisé lorsque l'équipe souhaite embarquer les derniers correctifs Flutter.
2. Tester sur iPad : travail hors ligne, fermeture/réouverture, retour en ligne, comparaison iPad/NocoDB/Web, puis génération PDF.
3. Simuler une indisponibilité API ou TLS et confirmer que l'utilisateur reste connecté, sans perte ni abandon d'opération.
4. Ajouter `EASYPANEL_API_WEBHOOK` aux secrets GitHub afin de rétablir le déploiement automatique de l'API.
5. Câbler la synchronisation des annotations PDF par page.
6. Décider du comportement au-delà de huit préconisations dans le rapport.
7. Valider une expiration réelle de session sur iPad et son renouvellement silencieux.
8. Vérifier un backup réel et le stockage documentaire.

Commandes de contrôle

```
npm run test:flutter
npm run test:sync-contract
npm run check:critical
npm run build
npm run build:pwa
npm run data:stability-check
npm run release:web-check -- --url https://app.aidhabitat.fr
npm run release:live-check
npm run secrets:audit
npm audit --omit=dev --audit-level=high
```